

Relatório Oficial SecOps - IA

Pentester

Meta-Dados do Alvo Laboratorial

Alvo (IP): Arquivo: Arquivo_Suspeito.zip (SHA-256:
2546dcffc5ad854d4ddc64fbf056871cd5a00f2471cb7a5bfd4ac23b6e9eedad)

Status:

Diagnóstico de Vulnerabilidades Detectadas pela IA

Detecção de Arquivo de Teste EICAR com Comportamentos de Sandbox Suspeitos

Explicação Técnica:

O arquivo 'Arquivo_Suspeito.zip' foi identificado por **62 dos 75 motores antivírus** (excluindo os não suportados) como malicioso, com uma taxa de detecção extremamente alta. Os resultados dos motores (e.g., Lionice, Elastic, MicroWorld-eScan, ClamAV, Kaspersky, Microsoft, Avast, BitDefender, ESET-NOD32) consistentemente apontam para 'EICAR-Test-File', 'EICAR Test-NOT virus!!!!', 'Virus:DOS/EICAR_Test_File', 'EICAR-AV-Test', 'TROJAN'.

A análise de sandbox 'Zenbox' classificou-o como '**malicious**', identificando-o como 'MALWARE' e 'TROJAN' com o nome 'EICAR'. Curiosamente, 'Zenbox Linux' o classificou como 'harmless', o

que é esperado, pois o EICAR.COM é um arquivo de teste para sistemas DOS/Windows e não executaria em Linux.

É crucial entender que o **EICAR (European Institute for Computer Antivirus Research) Test File** não é um vírus real, mas sim um arquivo inofensivo projetado para ser detectado por software antivírus. Ele serve para testar a funcionalidade de um scanner de AV.

No entanto, a análise Sigma revelou **comportamentos preocupantes no ambiente de sandbox:**

- Uma regra de nível '**high**' foi acionada para '**Audit Policy Tampering Via Auditpol**', indicando que o comando ``auditpol /set /subcategory:"SAM" /success:disable /failure:disable`` foi executado. Este é um método comum de evasão de detecção por malware. O ``ParentCommandLine`` mostra ``C:\Users\sandbox\AppData\Local\Programs\Python\Python38-32\pythonw.exe C:/tmpx5trn8j4/analyzer.py``, sugerindo que a alteração da política de auditoria foi realizada pelo próprio analisador da sandbox durante a inspeção do arquivo.
- Uma regra de nível '**medium**' foi acionada para '**Rundll32 Internet Connection**', detectando múltiplas conexões de ``C:\Windows\system32\RunDll32.exe`` para o IP ``104.208.16.93`` (associado a Microsoft Azure) na porta ``443`` (HTTPS). Embora ``RunDll32`` seja um binário legítimo, seu uso para comunicação externa é frequentemente explorado por malware para C2 (Command and Control). Assim como o 'Auditpol', este comportamento foi observado no ambiente de sandbox e pode ser um artefato da análise ou uma tentativa de execução de um componente dentro do ZIP que, no caso do EICAR, é benigno.

Em resumo, o arquivo em si é o EICAR test file, que é benigno. Os comportamentos suspeitos foram observados no ambiente de sandbox e, embora alarmantes para malware real, são

provavelmente falsos positivos ou resultados da metodologia de análise da sandbox para um arquivo de teste como o EICAR.

Fluxograma Lógico (Código Mermaid.js Gerado):

```
graph TD
  A[Arquivo Suspeito zip] --> B{Analise VirusTotal}
  B --> C{Deteccao EICAR}
  C --> D[62 de 75 AVs Maliciosos]
  C --> E[Sandbox Zenbox Malicioso]
  B --> F{Analise de Comportamento Sandbox}
  F --> G[Audit Policy Tampering Alto]
  F --> H[Rundll32 Conexao Internet Medio]
  D --> I[Arquivo de Teste Benigno]
  E --> I
  G --> J[Comportamento de Sandbox]
  H --> J
  I --> K[Risco Real Baixo]
  J --> L[Potencial Falso Positivo]
  K --> M[Remover ou Validar Intencao]
  L --> M
```

Patch de Correção:

Ações Recomendadas

Dado que o arquivo é o EICAR Test File, as ações devem focar na validação e na compreensão do contexto.

1. Confirmação e Contexto

- **Verificar Intenção:** Determine se o 'Arquivo_Suspeito.zip' foi intencionalmente baixado ou criado como um arquivo de teste EICAR. Se sim, ele cumpriu seu propósito de verificar a funcionalidade do antivírus.
- **Validação do Antivírus:** A alta taxa de detecção confirma que os sistemas antivírus estão funcionando corretamente e são capazes de identificar ameaças conhecidas (mesmo que sejam arquivos de teste).

2. Mitigação e Remediação

- **Remoção Segura:** Se o arquivo não foi intencionalmente colocado para teste, ele deve ser removido imediatamente de qualquer sistema onde foi encontrado. Embora inofensivo, sua presença pode causar alarmes desnecessários e confusão.
- **Quarentena:** Mova o arquivo para uma área de quarentena segura, se necessário, para análise posterior, mas evite executá-lo ou abri-lo em ambientes de produção.
- **Análise de Origem:** Investigue como o arquivo chegou ao sistema. Isso pode indicar uma tentativa de teste de segurança interna ou, se não intencional, uma falha na política de segurança de e-mail/web que permitiu a entrada de arquivos ZIP com conteúdo suspeito (mesmo que benigno).

3. Abordagem aos Comportamentos de Sandbox

- **Revisão da Análise de Sandbox:** Os comportamentos de 'Audit Policy Tampering' e 'Rundll32 Internet Connection' são críticos para malware real. No contexto do EICAR, eles são provavelmente artefatos da própria análise da sandbox. Revise a configuração da sandbox para entender por que esses eventos foram acionados por um arquivo EICAR. Isso pode envolver:
 - Ajustar as regras Sigma para serem mais específicas e evitar falsos positivos com arquivos de teste.
 - Compreender o fluxo de execução da sandbox para diferenciar entre ações do arquivo analisado e ações do próprio ambiente de análise.
- **Monitoramento de Comportamento:** Mantenha o monitoramento rigoroso para esses tipos de comportamentos (alteração de políticas de auditoria, comunicação de `rundll32.exe` para IPs externos) em ambientes de produção, pois são indicadores fortes de atividade maliciosa real.

4. Conscientização de Segurança

- **Treinamento:** Reforce o treinamento de conscientização de segurança para os usuários sobre a importância de não abrir ou baixar arquivos de fontes desconhecidas, mesmo que pareçam inofensivos ou sejam identificados como 'arquivos de teste'.
- **Políticas de Uso:** Garanta que as políticas de uso aceitável e de segurança de e-mail/web estejam atualizadas e sejam comunicadas eficazmente.